



Da enumeração à vulnerabilidade

Aula 06 · Interpretando dados e planejando a investigação

Sistemas de Informação · Ensino noturno · 18h25–22h05

O ponto de partida

Na Aula 05, o terminal produziu evidências. Hoje, vamos decidir o que elas significam.

resultado.txt

Portas, estados, serviços e versões detectadas pelo Nmap.

banner.txt

Informações que o próprio serviço revelou durante a conexão.

Pergunta central

Qual achado merece investigação primeiro, e com qual evidência?

Guardar a saída foi o primeiro passo. Interpretar com método é o próximo.

Encontramos OpenSSH 8.x. E agora?

```
22/tcp open  ssh OpenSSH 8.x  
80/tcp open  http Apache httpd 2.4.x
```

**A versão sugere hipóteses.
Ela não confirma
vulnerabilidade, impacto nem
possibilidade de exploração.**

Nossa análise precisa ligar evidência, contexto e validação.

O que veremos hoje

Da saída do Nmap a um plano de investigação defensável.

- | | | | |
|----|---|----|--|
| 01 | Interpretar portas, serviços e versões | 02 | Distinguir exposição, vulnerabilidade, CVE e exploit |
| 03 | Ler CPE, CVSS 3.1 e CVSS 4.0 | 04 | Pesquisar em fontes confiáveis |
| 05 | Validar aplicabilidade e reduzir falsos positivos | 06 | Priorizar achados e registrar evidências |
| 07 | Prática guiada com resultado.txt | 08 | Atividade em duplas e fechamento |

Como a aula vai funcionar hoje

BLOCO 1

Leitura técnica da enumeração e qualidade da evidência.

BLOCO 2

CVE, CPE, CVSS e fontes de consulta.

INTERVALO

Pausa de 15 minutos antes da prática.

BLOCO 3

Prática guiada, atividade e priorização.

Meta da noite: explicar por que um achado merece o próximo passo.

Interpretação de dados e identificação de processos

Estudaremos como transformar dados de reconhecimento em hipóteses de vulnerabilidade.

Aprenderemos a correlacionar serviço, versão, configuração, CVE, gravidade e exploit.

Refletiremos sobre como planejar uma investigação sem confundir indício com confirmação.

O resultado esperado

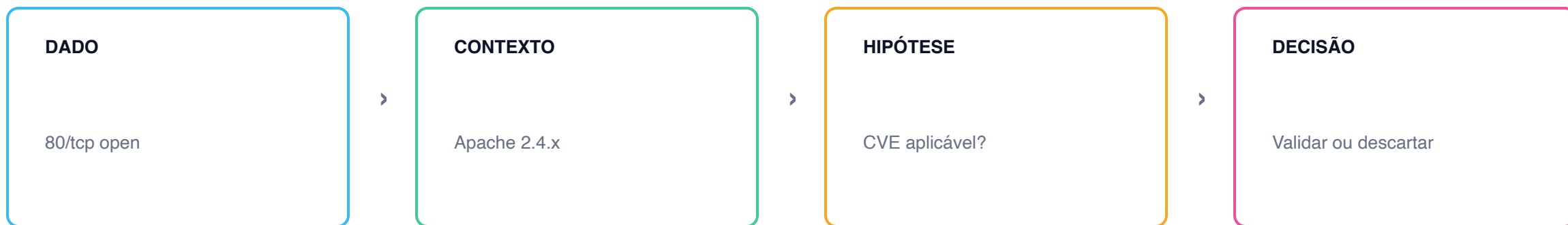
COMPETÊNCIA

Analisar ferramentas online e locais para exploração de vulnerabilidades, identificando possibilidades de ataque.

OBJETIVOS

Interpretar evidências de enumeração.
Pesquisar vulnerabilidades em fontes confiáveis.
Avaliar aplicabilidade e prioridade.
Planejar próximos testes em ambiente autorizado.

Dado, informação e decisão



A ferramenta coleta sinais. O analista constrói significado e escolhe o próximo teste.

O que cada coluna responde

```
22/tcp open  ssh  OpenSSH 8.9p1 Ubuntu 3ubuntu0.6
```

22/tcp

Qual porta e protocolo de transporte?

open

Como o alvo respondeu ao scan?

ssh

Qual serviço o Nmap inferiu?

versão

Qual produto e build parecem ativos?

Aberta não significa vulnerável

open: existe uma aplicação aceitando conexões.

closed: o host respondeu, mas não há serviço escutando.

filtered: algum controle impediu a conclusão do scan.

open|filtered: a resposta não permitiu distinguir os dois estados.

Estado de porta descreve conectividade. Vulnerabilidade exige uma condição explorável.

Produto, versão e build

Produto

OpenSSH, Apache HTTP Server, nginx, MySQL.

Versão

8.9p1, 2.4.57, 1.24.0, 5.7.44.

Build e distribuição

Pacotes podem receber correções sem mudar para a versão mais nova.

O backport de patches é uma das principais causas de falso positivo em análise por versão.

Fontes de identificação

Banner

Resposta direta do serviço

Nmap -sV

Sondas e assinaturas

HTTP headers

Server, cookies e tecnologias

Comportamento

Recursos e respostas observadas

Quanto mais fontes independentes concordarem, melhor a confiança.

Confiança da evidência

BAIXA

Inferência genérica: “servidor web em 80/tcp”.

MÉDIA

Nmap identifica produto e família de versão.

ALTA

Banner, resposta HTTP e comportamento confirmam a mesma build.

Registre como você chegou à conclusão. A confiança também faz parte do achado.

Exposição, fraqueza e vulnerabilidade

EXPOSIÇÃO

Um serviço está acessível a partir de determinada origem.

FRAQUEZA

Configuração ou implementação reduz a segurança esperada.

VULNERABILIDADE

Uma condição pode causar impacto quando explorada.

A mesma exposição pode ser necessária ao negócio e ainda exigir controles.

CVE, CWE e exploit

CVE

Identificador de um registro público de vulnerabilidade.

CWE

Categoria de fraqueza, como validação inadequada de entrada.

Exploit ou PoC

Código ou procedimento que demonstra ou aproveita uma condição.

Um CVE pode não ter exploit público. Um exploit pode exigir condições ausentes no alvo.

Anatomia de um CVE

CVE-2024-12345

CVE

programa de identificação

2024

ano da atribuição

12345

sequência única naquele ano

O identificador organiza a conversa. O registro contém descrição, referências e produtos afetados.

CPE liga o produto ao registro

```
cpe:2.3:a:vendor:produto:versao:*.~*~*~*~*~*
```

a

Tipo: application

vendor / produto

Fabricante e nome normalizado

versão

Faixa que precisa ser conferida

CPE ajuda na correlação, mas nomes e faixas ainda precisam de validação.

Gravidade não é prioridade

CVSS

Mede características técnicas de gravidade com um vetor padronizado.

PRIORIDADE

Combina gravidade com exposição, criticidade do ativo, controles e exploração observada.

Um score alto em um sistema isolado pode ficar atrás de uma falha explorada em produção.

CVSS 3.1 e CVSS 4.0

CVSS 3.1

Base, Temporal e Environmental.
Métricas comuns: AV, AC, PR, UI, S, C, I e A.

CVSS 4.0

Base, Threat, Environmental e Supplemental.
Separa melhor impacto no sistema vulnerável e em sistemas subsequentes.

Ao registrar um score, informe também a versão do CVSS e o vetor completo.

Métricas de explorabilidade

AV

Vetor de ataque

AC

Complexidade

PR

Privilégios exigidos

UI

Interação do usuário

Pergunta de leitura: quais condições o atacante precisa reunir antes de causar impacto?

Escopo e impacto

S

O impacto atravessa a fronteira de segurança?

C

Confidencialidade

I

Integridade

A

Disponibilidade

O vetor descreve a vulnerabilidade. O contexto do ativo define a urgência real.

Exemplo de vetor CVSS 3.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Rede

Baixa

Nenhum privilégio

Sem interação

Escopo inalterado

Impacto alto em C/I/A

O que mudou na leitura



Threat incorpora maturidade de exploração ao cálculo contextual.



Environmental adapta o resultado ao ambiente avaliado.



Supplemental registra informações úteis sem alterar o score base.



Automatable, Recovery e Safety ajudam a qualificar a resposta.

Onde pesquisar

CVE.org

Registro e referências do programa CVE.

NVD

Enriquecimento, CPE, CVSS e referências.

Advisory

Fabricante, versões afetadas e correção.

Exploit-DB

PoCs e pesquisa local via SearchSploit.

Priorize fontes primárias para confirmar produto, faixa afetada e correção.

Pesquisa por produto e versão

Pesquise o nome exato do produto e a versão observada.

Abra o registro e confira descrição, CPE e intervalo de versões.

Leia as referências do fabricante e notas de atualização.

Registre CVSS com versão e vetor, sem copiar apenas o número.

A fonte do fabricante

CONFIRMA

Produtos afetados, versões corrigidas, pré-condições e mitigação.

EXPLICA

Backports, diferenças entre builds, configuração necessária e impacto real.

Quando NVD e advisory parecem discordar, entenda o pacote e a distribuição antes de concluir.

Pesquisa local no Kali

```
searchsploit openssh  
searchsploit "Apache 2.4"  
searchsploit --cve 2021-41773  
searchsploit -x 50383
```

ANTES DE EXECUTAR

Leia o código.
Confirme alvo e versão.
Revise dependências.
Use somente em laboratório autorizado.

A existência de um PoC aumenta a relevância da hipótese, não prova aplicabilidade.

Código público exige revisão

01

O código corresponde ao mesmo produto?

02

A versão e a arquitetura coincidem?

03

A configuração necessária existe?

04

O teste pode causar indisponibilidade?

Nunca execute código desconhecido diretamente em produção.

Cadeia de análise



Em qualquer etapa, evidência insuficiente devolve a investigação ao passo anterior.

Por que a versão pode enganar

O fornecedor aplicou backport do patch.

O banner foi ocultado, alterado ou permanece desatualizado.

A funcionalidade vulnerável está desabilitada.

O exploit exige módulo, sistema operacional ou arquitetura diferentes.

Conclusão correta: “potencialmente afetado, pendente de validação”.

Da hipótese à confirmação

1. REPRODUZIR

Confirme a evidência inicial.

2. CONTEXTUALIZAR

Mapeie build, configuração e exposição.

3. TESTAR

Escolha teste seguro e autorizado.

4. DOCUMENTAR

Registre resultado e limitações.

Validação boa também consegue explicar por que uma hipótese foi descartada.

O que investigar primeiro

Exploração ativa

Há abuso conhecido ou evidência local?

Exposição

O serviço está acessível ao atacante?

Impacto

O ativo e os dados são críticos?

Viabilidade

Existem pré-condições e controles?

CVSS ajuda, mas a fila de trabalho precisa do contexto.

Modelo simples de prioridade

Urgente

Exposto, aplicável, alto impacto ou exploração observada

Alta

Condições presentes e ativo importante

Média

Hipótese plausível, com controles ou impacto limitado

Baixa

Pouca evidência, sem exposição ou não aplicável

Superfície de ataque observável

EXTERNA

Serviços alcançáveis pela internet, DNS, certificados, APIs e painéis.

INTERNA

Serviços corporativos, administração, bancos de dados e protocolos legados.

LOCAL

Software instalado, permissões, credenciais e configurações do host.

A origem do teste muda o que está exposto e quais controles entram no caminho.

Perguntas antes de buscar CVE

- Qual é o produto exato, a versão, a build e a distribuição?
- O serviço está exposto para qual rede e quais usuários?
- Há autenticação, proxy, WAF, segmentação ou outro controle?
- A funcionalidade vulnerável está ativa e acessível?
- Qual impacto o comprometimento teria para o negócio?

Informações além do banner

```
curl -I http://<ALVO>  
curl -vk https://<ALVO>/  
whatweb http://<ALVO>  
nmap -p80,443 --script http-title,http-headers <ALVO>
```

OBSERVE

Redirecionamentos, headers, cookies, título, TLS, virtual hosts e tecnologias aparentes.

Headers podem omitir ou falsificar o produto. Confirme com outras evidências.

Certificados e configuração criptográfica

```
openssl s_client -connect <ALVO>:443 -servername <HOST>  
nmap -p443 --script ssl-cert,ssl-enum-ciphers <ALVO>
```

EVIDÊNCIAS

CN/SAN, emissor, validade, protocolos e conjuntos de cifras.

O certificado também revela nomes internos ou virtuais que merecem enumeração autorizada.

Intensidade da detecção de versão

```
nmap -sV --version-light <ALVO>  
nmap -sV --version-intensity 7 <ALVO>  
nmap -sV --version-all <ALVO>  
nmap -sV --version-trace <ALVO>
```

ESCOLHA

Maior intensidade envia mais sondas e pode aumentar tempo, ruído e risco operacional.

Use version-trace para entender por que o Nmap chegou a uma identificação.

CVSS, EPSS e KEV respondem perguntas diferentes

CVSS

Quão grave pode ser a vulnerabilidade sob condições definidas?

EPSS

Qual a probabilidade estimada de exploração nos próximos 30 dias?

CISA KEV

Há evidência de exploração conhecida no mundo real?

Combine os sinais com exposição e criticidade. Nenhum deles decide sozinho.

Probabilidade e percentil

SCORE

Probabilidade entre 0 e 1 de exploração observada nos 30 dias seguintes.

PERCENTIL

Posição relativa do CVE quando comparado aos demais registros avaliados.

O valor muda diariamente. Registre a data da consulta e evite tratar EPSS como certeza.

Exploração conhecida

O catálogo reúne vulnerabilidades com evidência de exploração ativa.

A presença no KEV aumenta a urgência da análise e da remediação.

A ausência no catálogo não demonstra que o CVE seja seguro.

Confirme se o produto e a versão do ambiente estão realmente afetados.

Uma decisão com quatro dimensões

Aplicabilidade

A condição existe no alvo?

Exposição

Quem consegue alcançá-la?

Impacto

O que o atacante poderia afetar?

Ameaça

Há exploit, EPSS alto ou KEV?

Prioridade cresce quando as quatro dimensões apontam na mesma direção.

Apache HTTP Server 2.4.49

```
80/tcp open http Apache httpd 2.4.49  
GET / HTTP/1.1  
Server: Apache/2.4.49
```

HIPÓTESE

Investigar CVE-2021-41773 e as condições para path traversal.

O estudo usa uma versão histórica em laboratório. Não teste serviços públicos.

O que a pesquisa precisa confirmar



O problema afeta Apache HTTP Server 2.4.49.



A exploração depende de configuração específica de arquivos e aliases.



O impacto pode incluir leitura de arquivos fora do diretório esperado.



A versão 2.4.50 corrigiu a falha de forma incompleta e recebeu outro CVE.

Evidência necessária

VERSÃO

A coleta confirma exatamente 2.4.49?

CONFIGURAÇÃO

O alias e o acesso ao caminho vulnerável estão presentes?

IMPACTO

A resposta comprova leitura indevida sem alterar o sistema?

Um teste seguro coleta somente a evidência mínima para confirmar ou descartar.

Conclusões possíveis

CONFIRMADO

Versão, configuração e comportamento correspondem à vulnerabilidade.

NÃO APLICÁVEL

Produto presente, mas versão ou condição necessária não existe.

INCONCLUSIVO

Evidência insuficiente ou teste seguro não pôde ser executado.

“Inconclusivo” é melhor que afirmar algo sem evidência.

Registro de achado técnico

Título	Produto, condição e impacto principal
Evidência	Comando, saída, data, origem e alvo
Aplicabilidade	Versão, build, configuração e exposição
Risco	CVSS, EPSS, KEV, ativo e controles
Correção	Versão corrigida, mitigação e responsável
Reteste	Critério objetivo para encerramento

Ambiente e limites

ALVO AUTORIZADO

VM de laboratório, Metasploitable ou serviço fornecido pelo professor.

REGRA

Pesquisa e validação apenas no escopo definido. Nada de testar sistemas públicos.

Crie uma pasta para guardar comandos, saídas e referências.

Ler e filtrar o resultado

```
cat resultado.txt  
grep "open" resultado.txt  
grep -E "open|Service Info" resultado.txt  
nmap -sV -oN versoes.txt <ALVO>
```

ENTREGA PARCIAL

Liste porta, serviço, versão e confiança de identificação.

Se faltar versão, planeje uma coleta adicional antes da pesquisa por CVE.

Construir uma hipótese

SERVIÇO: Apache HTTP Server
VERSÃO: 2.4.x
EVIDÊNCIA: Nmap + header HTTP
HIPÓTESE: pesquisar faixa afetada
FALTA: build exata e distribuição

PERGUNTA

Qual informação mudaria sua decisão de investigar ou descartar?

Uma hipótese clara inclui o que sabemos e o que ainda falta.

Pesquisar e registrar

Campo	Registro
Produto e versão	
CVE e descrição	
Faixa afetada	
CVSS, EPSS e KEV	
Exploit ou PoC	
Evidência e próximo passo	

Teste de aplicabilidade

Compare a versão observada com a faixa afetada.

Confira sistema operacional, arquitetura, módulo e configuração.

Escolha uma verificação não destrutiva quando possível.

Registre resultado, limitações e evidência produzida.

Pare se o teste sair do escopo ou puder comprometer a disponibilidade.

Três serviços, uma decisão

```
22/tcp  open  ssh      OpenSSH 7.6p1  
80/tcp  open  http     Apache httpd 2.4.x  
3306/tcp open  mysql    MySQL 5.7.x
```

DESAFIO

Escolham qual achado investigar primeiro e defendam a escolha.

Não presuma vulnerabilidade apenas pela versão apresentada.

Matriz de análise

Porta	Serviço	Versão	CVE	CVSS	Exploit?	Evidência	Próximo passo

Incluem links das fontes consultadas e indiquem o nível de confiança.

Como a atividade será avaliada

EVIDÊNCIA

A versão e a exposição foram justificadas?

PESQUISA

As fontes confirmam a faixa afetada?

ANÁLISE

As pré-condições e falsos positivos foram considerados?

DECISÃO

A prioridade e o próximo passo fazem sentido?

Tempo sugerido: 30 minutos de análise e 5 minutos de apresentação por grupo.

Verificação rápida

Por que uma porta aberta não confirma vulnerabilidade?

Qual diferença entre CVE, CWE e exploit?

Como CVSS, EPSS e KEV se complementam?

Cite duas causas de falso positivo por versão.

Quais fatores, além do CVSS, alteram a prioridade?

Roteiro do professor

Porta aberta confirma um serviço acessível, não uma condição explorável.

CVE identifica o registro, CWE classifica a fraqueza e exploit demonstra ou aproveita a falha.

CVSS indica gravidade, EPSS estima probabilidade e KEV registra exploração conhecida.

Backport de patch, banner impreciso, funcionalidade desativada ou pré-condição ausente.

Exposição, criticidade do ativo, controles, aplicabilidade e exploração observada.

Matriz de superfície de ataque

ENTREGA

Selecione um serviço do laboratório. Registre versão, fonte, CVE pesquisado, CVSS, EPSS/KEV, evidência, aplicabilidade e próximo passo.

CUIDADO

Não execute exploit. A tarefa termina no planejamento de validação e na justificativa de prioridade.

Trazer o arquivo para discussão no início da próxima aula.

Validação segura de vulnerabilidades



Confirmação de versões e configurações.



Testes não destrutivos e evidências reproduzíveis.



Uso responsável de scripts NSE e scanners de vulnerabilidade.



Planejamento de exploração em ambiente controlado.

ENCERRAMENTO

Dúvidas?

Prof. José Carlos Neto
j.neto@ufn.edu.br